

LVChat

Full Monty Audit Report

3 CRITICAL · 11 HIGH · 16 MEDIUM · 0 LOW

Generated: August 18, 2026 at 10:35 PM
Scope: FULL_MONTY
Total findings: 30 · Security: 4 · Performance: 13 · UI/UX: 13

Executive Summary

Metric	Value
Total Findings	30
Critical Severity	3
High Severity	11
Medium Severity	16
Low Severity	0
---	---
Security findings	4
Performance findings	13
UI/UX findings	13
---	---
GPT-OSS-20b findings	0
MiniMax/grep findings	0

Methodology

Security scan (Step 2.5): Two-model parallel approach. Model A — GPT-OSS-20b at 192.168.8.147:1234 (Botbox2): static per-file security review using a 6-thread worker pattern. Model B — MiniMax + local grep sweep: regex/heuristic pass over all source files. Vulnerability classes scanned: SQLi, XSS, CSRF, IDOR,

AuthBypass, HardcodedSecret, SessionHardening, FileUpload/PathTraversal, TimingAttack, Cron/TOCTOU, InfoDisclosure, InsecureDeserialization, OpenRedirect, MissingRateLimit, CORS/OriginCheck, HeaderInjection.

Performance scan (Step 2.6): Same two-model pattern. Classes scanned: N+1, MissingIndex, UnboundedResultSet, SyncExternalCall, MissingCache, AssetBloat, RenderBlocking, ExcessiveDOM, MemoryHotPath, ResourceLeaks, CronInefficiency, ColdStart, FrontendRuntime, NetworkPayload, ConnectionPool, Concurrency.

UI/UX scan (Step 2.7): Same two-model pattern plus Playwright screenshot review where available. Classes scanned: a11y, FormUX, LoadingStates, ErrorUX, InformationArchitecture, VisualConsistency, ResponsiveDesign, i18n, StateFeedback, Discoverability, NativeDialog, DataBinding, DeadUI, ColorContrast, Microcopy, Motion, PrintExport.

Severity scale: Critical (direct exploit / unusability) → High (realistic exploit / visible breakage) → Medium (preconditions / tolerable lag) → Low (defense-in-depth / polish).

Scope rule (CRITICAL): *install/*, *e2e/*, and *tests/* directories are excluded from live-code audit scope. They are development-only and must never reach production. These folders should be manually deleted before any upload.

Security Findings

4 finding(s): 0 Critical · 0 High · 4 Medium · 0 Low

H-01	MEDIUM	Missing Security Header	Round 1
File : Line	src/bootstrap.php : 197		
Vulnerable Code	// HSTS only		
Description	No CSP, X-Content-Type-Options, or Referrer-Policy headers.		
Remediation	Added CSP, X-Content-Type-Options: nosniff, Referrer-Policy.		

H-02	MEDIUM	LIKE Wildcard Injection	Round 1
File : Line	src/controllers/AdminController.php : 118		
Vulnerable Code	\$params = ["%\$term%"]		
Description	User search LIKE without wildcard escaping.		
Remediation	addslashes(\$term, '%_\\').		

H-03	MEDIUM	LIKE Wildcard Injection	Round 3
File : Line	src/controllers/AdminController.php : 232		
Vulnerable Code	\$params = ["%\$term%"]		
Description	Channel search LIKE without wildcard escaping.		
Remediation	addslashes escaping.		

H-04	MEDIUM	LIKE Wildcard Injection	Round 3
File : Line	src/controllers/FriendController.php : 199		
Vulnerable Code	'%' . \$q . '%'		
Description	Directory search LIKE without wildcard escaping.		
Remediation	addslashes(\$q, '%_\\').		

Performance Findings

13 finding(s): 2 Critical · 4 High · 7 Medium · 0 Low

P-01	HIGH	Missing Index	Round 1
File : Line	schema.sql : 4		
Vulnerable Code	users.last_ip, last_seen		
Description	No indexes on users.last_ip or last_seen.		
Remediation	Added idx_users_last_seen, idx_users_last_ip.		

P-02	HIGH	Missing Index	Round 1
File : Line	schema.sql : 250		
Vulnerable Code	chat_logs.channel_name		
Description	No index on chat_logs.channel_name.		
Remediation	Added idx_chat_logs_channel.		

P-03	MEDIUM	Missing Caching	Round 1
File : Line	src/services/UrlBanService.php : 73		
Vulnerable Code	Database::all('SELECT * FROM banned_urls')		
Description	Full table scan on every embed/URL check.		
Remediation	Per-request static cache.		

P-04	CRITICAL	N+1 Query	Round 1
File : Line	src/services/MessageService.php : 89		
Vulnerable Code	8 correlated subqueries per row		
Description	480+ queries per 60-message page.		
Remediation	Replaced with LEFT JOINS.		

P-05	CRITICAL	Full Table Scan	Round 1
File : Line	src/services/commands/OperCommands.php : 178		
Vulnerable Code	SELECT * FROM users WHERE last_ip IS NOT NULL		
Description	Loaded every user for IP ban match.		
Remediation	SELECT id, username, last_ip + index.		

P-06	HIGH	Unbounded Result Set	Round 1
File : Line	src/services/EventLogService.php : 134		
Vulnerable Code	SELECT * no LIMIT		
Description	Fetched ALL log rows unbounded.		
Remediation	Time-range + LIMIT 50000.		

P-07	MEDIUM	N+1 Query	Round 1
File : Line	src/services/PushService.php : 371		
Vulnerable Code	SELECT * per user per notify		
Description	Redundant subscription fetches.		
Remediation	Per-request static cache.		

P-08	MEDIUM	Render Blocking	Round 1
File : Line	views/chat/app.php : 1374		
Vulnerable Code	<script> no defer		
Description	5 script tags without defer.		
Remediation	Added defer.		

P-09	HIGH	Missing Index	Round 3
File : Line	schema.sql : 118		
Vulnerable Code	bans.active, kind, channel_id		
Description	No composite index on bans hot path.		
Remediation	Added idx_bans_active_kind_channel.		

P-10	MEDIUM	Missing Index	Round 3
File : Line	schema.sql : 108		
Vulnerable Code	akick.channel_id		
Description	No index on akick.channel_id.		
Remediation	Added idx_akick_channel.		

P-11	MEDIUM	Missing Index	Round 3
File : Line	schema.sql : 140		

Vulnerable Code	spamfilters.enabled
Description	No index on spamfilters.enabled.
Remediation	Added idx_spamfilters_enabled.

P-12	MEDIUM	Missing Index	Round 3
File : Line	schema.sql : 88		
Vulnerable Code	channel_members.user_id, guest_id		
Description	No indexes for reverse lookups.		
Remediation	Added idx_channel_members_user + guest.		

P-13	MEDIUM	Missing Index	Round 4
File : Line	schema.sql : 145		
Vulnerable Code	private_messages.recipient		
Description	No index for DM recipient lookups.		
Remediation	Added idx_pm_recipient composite index.		

UI/UX Findings

13 finding(s): 1 Critical · 7 High · 5 Medium · 0 Low

U-01	CRITICAL	Accessibility	Round 1
File : Line	views/layout.php : 52		
Vulnerable Code	alt=""		
Description	Logo empty alt on every page.		
Remediation	alt with site name across 7 views.		

U-02	HIGH	Accessibility	Round 1
File : Line	views/chat/app.php : 711		
Vulnerable Code	<textarea> no label		
Description	Chat textarea had no label.		
Remediation	aria-label="Message input".		

U-03	HIGH	Accessibility	Round 1
File : Line	views/chat/join.php : 31		
Vulnerable Code	<input> no label		
Description	Channel key input had no label.		
Remediation	Added <label>.		

U-04	HIGH	Accessibility	Round 1
File : Line	views/browse/index.php : 99		
Vulnerable Code	no aria-label		
Description	Browse search/filter missing labels.		
Remediation	Added aria-label.		

U-05	HIGH	Motion	Round 1
File : Line	src/assets/input.css : 379		
Vulnerable Code	@keyframes no reduced-motion		
Description	5 animations without prefers-reduced-motion.		
Remediation	Added @media (prefers-reduced-motion: reduce).		

U-06	HIGH	Print	Round 1
File : Line	src/assets/input.css : 304		
Vulnerable Code	body fixed no print		
Description	No @media print.		
Remediation	Added print stylesheet.		

U-07	HIGH	Tap Targets	Round 1
File : Line	public/assets/js/app.js : 336		
Vulnerable Code	px-2 py-0.5		
Description	Buttons below 44px WCAG min.		
Remediation	Increased to py-1, p-2.5.		

U-08	HIGH	Accessibility	Rounds 1-4
File : Line	views/chat/app.php : 919		
Vulnerable Code	13 modals no ARIA		
Description	All modals lacked role/aria-modal/aria-labelledby.		
Remediation	Added to all 13 modals + LVCDialog.		

U-09	MEDIUM	Form UX	Round 3
File : Line	views/auth/register.php : 79		
Vulnerable Code	checkbox no name		
Description	Terms checkbox missing name attr.		
Remediation	Added name="terms".		

U-10	MEDIUM	Accessibility	Round 3
File : Line	src/assets/input.css : 96		
Vulnerable Code	.btn no focus-visible		
Description	Buttons had no visible focus ring.		
Remediation	Added focus-visible:ring-2.		

U-11	MEDIUM	Accessibility	Round 4
File : Line	views/chat/app.php : 882		

Vulnerable Code	error containers no aria-live
Description	5 error/success containers lacked aria-live.
Remediation	Added aria-live="polite".

U-12	MEDIUM	Accessibility	Round 4
File : Line	public/assets/js/app.js : 1567		
Vulnerable Code	JS avatar alt=""		
Description	3 JS avatar renders had empty alt.		
Remediation	Added alt with username.		

U-13	MEDIUM	Native Dialog	Round 4
File : Line	modules/saas : 79		
Vulnerable Code	confirm()		
Description	SaaS module used native confirm().		
Remediation	Replaced with data-confirm (LVCDialog).		